

False Positive Report — AI Email Reply Generator

False Positive Report — AI Email Reply Generator

Package: AI Email Reply Generator
Namespace: aiemailreply
API Version: 60.0
Date: May 7, 2026
Prepared by: Alex Morgun (omorgun@morgunsolutions.com)

Overview

This document explains all scanner suppressions in the AI Email Reply Generator managed package. Each suppression is intentional, justified, and documented below for the AppExchange security review team.

Scanner results: Salesforce Code Analyzer v0.45.0 reports **2 violations** (both severity-3 false positives) as of May 7, 2026. All other engines (ESLint, CPD, RetireJS) report 0 violations. The 2 violations are documented below as items 4 and 5 in the Summary table.

DAST: Not applicable. This is a 100% native Salesforce Lightning managed package. MDS LLC operates no web servers, APIs, mobile applications, or ISV-hosted infrastructure. All external HTTP callouts originate from within the customer’s Salesforce org and are directed to the customer’s own AI provider account. There is no ISV-controlled endpoint to scan.

Suppression 1: ApexCRUDViolation — Custom Metadata Type Queries

Rule: PMD ApexCRUDViolation
File: force-app/main/default/classes/AIReplyConfigService.cls
Lines: Methods getActiveConfig(), getAnyConfig(), getPromptTemplate(), getDefaultPromptTemplate(), getAllTemplates()
Annotation: @SuppressWarnings('PMD.ApexCRUDViolation') and // NOPMD

Justification

These methods query **Custom Metadata Types** (AI_Email_Reply_Config__mdt and AI_Email_Reply_Prompt_Template__mdt). Custom Metadata Types are:

- 1. **Read-only at runtime** — they cannot be inserted, updated, or deleted via DML in Apex. They are deployed as metadata, not data.
- 2. **Not subject to CRUD/FLS enforcement** — Salesforce does not enforce object-level or field-level security on Custom Metadata Type records. All users with access to the Apex class can read CMDT records regardless of profile/permission set configuration.
- 3. **Org-wide configuration** — these records store application settings (AI provider, model, temperature, default tone, prompt templates) that must be readable by all app users to function.

Applying WITH SECURITY_ENFORCED or Security.stripInaccessible() to CMDT queries is unnecessary and can cause false runtime failures in orgs where CMDT permissions are not explicitly granted (which is the default, since CMDT doesn’t participate in the standard permission model).

References

- [Salesforce Documentation: Custom Metadata Types](#) — “Custom metadata records are read-only in Apex.”
- [ISVforce Guide: CRUD/FLS](#) — CRUD/FLS applies to standard and custom objects, not Custom Metadata Types.

Affected Queries

Method	Object	Suppression
getActiveConfig()	AI_Email_Reply_Config__mdt	@SuppressWarnings('PMD.ApexCRUDViolation')
getAnyConfig()	AI_Email_Reply_Config__mdt	@SuppressWarnings('PMD.ApexCRUDViolation')
getPromptTemplate()	AI_Email_Reply_Prompt_Template__mdt	// NOPMD inline
getDefaultPromptTemplate()	AI_Email_Reply_Prompt_Template__mdt	@SuppressWarnings('PMD.ApexCRUDViolation')
getAllTemplates()	AI_Email_Reply_Prompt_Template__mdt	@SuppressWarnings('PMD.ApexCRUDViolation')

Suppression 2: AvoidDebugStatements — Centralized Error Logger

Rule: PMD AvoidDebugStatements
File: force-app/main/default/classes/AIReplyLogger.cls
Line: Class-level annotation
Annotation: @SuppressWarnings('PMD.AvoidDebugStatements')

Justification

AIReplyLogger is a **centralized error logging utility** that consolidates all System.debug() calls into a single class. This pattern:

- 1. **Reduces the attack surface** — instead of System.debug() scattered across 4+ classes, all logging flows through one controlled method (logError()).
- 2. **Enforces security policy** — the logError() method only logs e.getMessage() at LoggingLevel.ERROR. It never logs stack traces (e.getStackTraceString()), PII, API keys, or request/response bodies.

3. **Preserves essential diagnostics** — error-level logging is necessary for production troubleshooting. Removing all debug statements would make the app unsupportable.

The suppression is applied at the class level because this is the only class in the package that calls `System.debug()`. All other classes call `AIReplyLogger.logError()` instead.

What is NOT logged

- Stack traces (`e.getStackTraceString()`)
- API request or response bodies
- Email content, sender/recipient addresses
- API keys, tokens, or credentials
- Session IDs or user-identifiable data

Calling Classes

Class	Calls to <code>AIReplyLogger.logError()</code>
<code>AIEmailReplyController</code>	8
<code>AIReplyAdminController</code>	3
<code>AIProviderCalloutService</code>	1
<code>AIProviderResponseParser</code>	1

Summary

#	Rule	File	Count	Verdict
1	ApexCRUDViolation	<code>AIReplyConfigService.cls</code>	5	False positive — CMDT not subject to CRUD/FLS
2	AvoidDebugStatements	<code>AIReplyLogger.cls</code>	1	Intentional — centralized error-only logging
3	AvoidGlobalInstallUninstallHandlers	<code>PostInstallHandler.cls</code>	1	Managed package API surface constraint — <code>PostInstallHandler</code> declared <code>global</code> in the first released version (v1.0). Salesforce prohibits downgrading global identifiers in a managed package published (error: “Global/WebService identifiers cannot be re-managed application”). The global modifier is permanently suppressed via <code>@SuppressWarnings('PMD.AvoidGlobalInstallUninstallHandlers')</code>
4	ProtectSensitiveData	<code>AI_Email_Reply_Config__mdt/fields/Max_Tokens__c</code>	1	False positive — <code>Max_Tokens__c</code> is a numeric API call limit (not an auth token). The field name contains “Token” referring to language model tokens (units of text), not authentication credentials. Field type: <code>Number(18,0)</code> .
5	ProtectSensitiveData	<code>AI_Email_Reply_Draft__c/fields/Token_Count__c</code>	1	False positive — <code>Token_Count__c</code> is a numeric count of AI tokens consumed per draft (Integer). Not a credential or secret. Field type: <code>Number(18,0)</code> .

Total suppressions: 9
Active violations in report: 2 (items 4 and 5 — both false positives, not suppressible in XML metadata files)
True security issues: 0